

Protect Yourself from Phishing

How to recognize fraudulent messages, avoid risky clicks, and respond fast when something goes wrong.

What this session covers

Phishing remains one of the most common ways attackers steal credentials, money, and client information. This session gives staff a practical framework for spotting suspicious messages and handling them safely.

- How phishing attacks work across email, text message, portals, and collaboration tools
- How to identify suspicious requests even when the sender looks familiar
- How to protect accounts, devices, and client information before an attack succeeds
- What to do immediately if you suspect or respond to a bad message

Why phishing works so often

Attackers do not need sophisticated malware every time. Many breaches begin with a normal-looking message that creates urgency, fear, curiosity, or convenience. The goal is to make someone click first and think later.

- Messages often imitate banks, tax platforms, leadership, vendors, payroll, or delivery services.
- Scammers use timing well: deadlines, payment issues, MFA prompts, account locks, and urgent client requests.
- A successful click can expose passwords, install malware, redirect payments, or expose tax and bookkeeping records.
- Even careful employees can be targeted, which is why consistent verification matters more than confidence.

What suspicious messages usually look like

Red flags in the message

- Unexpected urgency or pressure to act now
- Requests to verify credentials, payment, or personal data
- Spelling, grammar, formatting, or tone that feels off
- Generic greetings or unfamiliar sign-offs
- Links or attachments you were not expecting

Red flags in the sender

- Display name looks familiar but address does not
- Domain is misspelled or slightly altered
- Reply-to address differs from the sender
- Text message comes from an unknown or strange short code
- Sender asks you to avoid normal firm verification steps

EXAMPLES

High-risk phishing scenarios for accounting firms

Phishing in tax and accounting environments often targets trust, money movement, and document exchange. If the request touches credentials, client files, payroll, refunds, wire instructions, or tax records, pause before acting.

- A fake client asks for prior returns, SSNs, or bank details through a rushed email chain.
- A spoofed leader requests gift cards, payroll changes, or urgent invoice payment.
- A portal or tax software message says your account is locked and asks you to sign in from an embedded link.
- A file-sharing email asks you to open a document or enable macros to view a return or engagement file.

PREVENTION

How to protect yourself before an attack lands

Good phishing defense is a stack of habits. Technology helps, but users still make the final decision to trust, click, reply, open, or report.

- ☐ Use multi-factor authentication on firm accounts, email, cloud storage, and any system that handles protected data.
- ☐ Keep browsers, operating systems, endpoint protection, and business apps updated automatically where approved.
- ☐ Use password managers or approved credential practices instead of reusing passwords across systems.
- ☐ Back up critical business data and make sure restore procedures are tested, not just assumed.
- ☐ Verify unusual requests through a separate known-good channel before taking action.

What to do when a message feels suspicious

When in doubt, slow down. The safest move is to verify first and click never. A few extra minutes of confirmation is cheaper than a credential compromise or client-data incident.

- ☐ Do not click links, download files, or call numbers included in the suspicious message.
- ☐ Hover over links and inspect sender details, but do not rely on appearance alone.
- ☐ Contact the company, vendor, or coworker using a phone number or website you already trust.
- ☐ Report the message internally so other staff can be warned quickly if needed.
- ☐ If the request involves money, payroll, tax data, or credentials, require stronger verification.

If you clicked, replied, or entered information

Do not panic, but do not wait. Fast response reduces the chance that an attacker can expand access, persist in your account, or use your session to target coworkers or clients.

- Disconnect or isolate the affected device if instructed by IT or the Data Security Coordinator.
- Reset passwords immediately for the impacted account and any reused credentials, then enforce MFA if not already enabled.
- Notify the firm's security or incident contact right away with screenshots, timestamps, sender details, and what action you took.
- Run approved malware and endpoint scans, and preserve evidence instead of deleting suspicious messages or files.

Where phishing should be reported

Internal reporting

- Data Security Coordinator
- Principal Operating Officer or designated leadership contact
- IT or managed security support
- Any firm incident-reporting workflow already in place

External reporting

- FTC fraud reporting channels
- APWG phishing mailbox for phishing emails
- 7726 (SPAM) for phishing text messages where applicable
- Vendors, banks, or service providers if an account may be involved

What EasyWISP expects from every employee

Phishing defense is part of daily operating discipline. Employees, contractors, and temporary personnel should treat suspicious communications as a normal security event that deserves prompt escalation, not private judgment alone.

- Stay skeptical of urgency, secrecy, payment changes, login prompts, and requests for PII.
- Use approved systems and approved verification steps even when the request looks legitimate.
- Escalate quickly whenever you are unsure; uncertainty is a reason to report, not a reason to proceed.
- Review this training regularly and follow the firm's current WISP, email, and incident-handling policies.

REFERENCE

Learn more and stay current

This training summarizes well-known phishing-defense practices aligned with federal guidance and practical firm operations. Staff should continue reviewing the firm's WISP and any related security procedures issued internally.

- FTC phishing guidance and fraud reporting resources
- APWG reporting guidance for suspicious messages
- Firm-specific incident response and secure communications procedures
- Annual refresher training and periodic phishing-awareness reminders